03 Acciones correctivas preventivas mejoramiento SaborExpress

SABOREXPRESS — PROYECTO DE SOFTWARE

Yerson Stiven Cuellar Rubiano

Ficha de formación: 3145555

Expediente técnico y académico — APA 7

14 de octubre de 2026

Fuente documental: repositorios SaborExpressBack, SaborExpressWeb y SaborExpressMovil.

Las pruebas no ejecutadas se identifican como pendientes.

Acciones correctivas, preventivas y plan de mejoramiento

Proyecto: SaborExpress | **Autor / integrante:** Yerson Stiven Cuellar Rubiano | **Ficha:** 3145555 | **Fecha:** 14 de octubre de 2026 | **Versión documental:** 4.0

Estado de la evidencia: inspección documental y estática del código. Las pruebas de ejecución y los datos institucionales no aportados no se presumen realizados.

1. Criterio de evaluación

Se clasifican riesgos observables en diseño/código y brechas de evidencia. Se habla de **recomendaciones de corrección**, no de vulnerabilidades explotadas o incidentes reales, porque no se ejecutaron pruebas de seguridad ni explotación.

2. Registro de acciones

ID	Hallazgo/ riesgo	Acción	Prioridad	Responsable sugerido	Método	Cierre
AC-01	README Docs identificaba Supabase como backend	Corregir stack actual .NET	Alta	Documentación	Actualizar descripción y validarla contra csproj	README consistente
AC-02	Archivos vacíos de documentación	Reemplazarlos por contenido real	Alta	Documentación	Revisar formatos y todos los tamaños > 0	Inventario completo
AC-03	Apertura de CORS a rangos de dev	Restricción por entorno	Alta	Backend/ DevOps	Validar AllowedOrigins productivos	Test orígenes
AC-04	Migración automática en arranque	Revisión estrategia de liberación	Alta	Backend/DBA	Separar migration job	Despliegue controlado
AC-05	Webhook con cuerpo en log	Minimización y redacción de logs	Alta	Backend	Revisar PaymentControl ler	Sin datos sensibles
AC-06	Autorización por roles/objetos sin batería	Pruebas negativas intersede	Crítica	QA	Diseñar permisos sobre ID de recurso	Matriz de denegación
AC-07	Wompi sin evidencia de sandbox	Ensayar firma, duplicados y rechazo	Crítica	Backend/QA	Pruebas webhook	Evidencia idempotencia
AC-08	DB multi-proveedor no demostrada	Elegir motor y certificar migraciones	Alta	DBA	Integración motor seleccionado	Esquema validado
AC-09	README web/móvil de plantilla	Personalizar onboarding	Media	Frontend	Documentar navegación y env	Manual actualizado
AP-10	Falta repositorio visible de tests	Implementar CI y tests	Alta	QA/DevOps	Test suites + pipeline	Reporte verificado
AP-11	Diseño sin	Backup/restore	Alta	DevOps	Ensayo	Restauración

ID	Hallazgo/ riesgo	Acción	Prioridad	Responsable sugerido	Método	Cierre
	respaldo auditado	programado			desechable	aprobada
AP-12	Resultados de usabilidad ausentes	Sesiones éticas voluntarias	Media	UX	Protocolo con consentimiento	Resultados reproducibles

3. Priorización y seguimiento

Prioridad crítica: riesgos de doble cobro, autorización indebida y pérdida de integridad. Alta: configuración de producción y trazabilidad documental. Media: mejoras de UX y manuales. Cada hallazgo deberá asignarse, estimarse, revisarse en PR y cerrarse con una prueba. Las áreas asignadas son roles sugeridos, no personas designadas.

4. Lecciones y prevención

Documentar decisiones arquitectónicas por SHA; automatizar validación del inventario de rutas; usar un único catálogo de API exportado de Swagger; integrar tests de regresión para pagos y roles; mantener manuales sincronizados con cada release; revisar cambios de esquema por proveedor antes de publicar.

7. Registro de hallazgos y acciones con responsables propuestos

ID	Riesgo	Hallazgo o punto por validar	Impacto	Acción	Rol asignable
AC-01	Alto	Webhook no autenticado/idempotente	financiero y fraude	Ensayar checksum y evento duplicado; revisar referencia y BD	backend + QA
AC-02	Alto	Acceso entre sedes/propietarios	privacidad	Pruebas BOLA con dos sedes y titulares	backend + seguridad
AC-03	Alto	Migración al arranque en producción	disponibilidad de datos	Paso de migración único y backup	operaciones
AC-04	Medio	Descripción Supabase obsoleta en README	desinformación	Actualizar backend .NET 8 real	documentación
AC-05	Medio	Ausencia identificada de pruebas automatizadas	regresión	Crear proyecto test y CI de seguridad	QA
AC-06	Medio	README de clientes generado por plantilla	dificultad de instalación	Manuales de componentes y variables	web/móvil
AC-07	Alto	Datos privados en logs y repos	exposición legal	Escaneo secretos, redactar logs	seguridad
AC-08	Alto	CORS permisivo en entornos	orígenes maliciosos	Restringir orígenes por ambiente	operaciones

ID	Riesgo	Hallazgo o punto por validar	Impacto	Acción	Rol asignable
		productivos			
AC-09	Medio	Compatibilidad MySQL/Postgres/SQLServer no probada	fallos al migrar	Elegir DB oficial y test CI por motor	backend/DBA
AC-10	Medio	Contrato REST sin export OpenAPI versionado	ruptura entre clientes	publicar snapshot y diff en cada release	integraciones

AC-01. Webhook no autenticado/idempotente

Riesgo: Alto. **Consecuencia posible:** financiero y fraude. **Rol responsable sugerido:** backend + QA; el nombre definitivo requiere aprobación.

Corrección: Ensayar checksum y evento duplicado; revisar referencia y BD. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-02. Acceso entre sedes/propietarios

Riesgo: Alto. **Consecuencia posible:** privacidad. **Rol responsable sugerido:** backend + seguridad; el nombre definitivo requiere aprobación.

Corrección: Pruebas BOLA con dos sedes y titulares. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-03. Migración al arranque en producción

Riesgo: Alto. **Consecuencia posible:** disponibilidad de datos. **Rol responsable sugerido:** operaciones; el nombre definitivo requiere aprobación.

Corrección: Paso de migración único y backup. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-04. Descripción Supabase obsoleta en README

Riesgo: Medio. **Consecuencia posible:** desinformación. **Rol responsable sugerido:** documentación; el nombre definitivo requiere aprobación.

Corrección: Actualizar backend .NET 8 real. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-05. Ausencia identificada de pruebas automatizadas

Riesgo: Medio. **Consecuencia posible:** regresión. **Rol responsable sugerido:** QA; el nombre definitivo requiere aprobación.

Corrección: Crear proyecto test y CI de seguridad. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-06. README de clientes generado por plantilla

Riesgo: Medio. **Consecuencia posible:** dificultad de instalación. **Rol responsable sugerido:** web/móvil; el nombre definitivo requiere aprobación.

Corrección: Manuales de componentes y variables. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-07. Datos privados en logs y repos

Riesgo: Alto. **Consecuencia posible:** exposición legal. **Rol responsable sugerido:** seguridad; el nombre definitivo requiere aprobación.

Corrección: Escaneo secretos, redactar logs. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-08. CORS permisivo en entornos productivos

Riesgo: Alto. **Consecuencia posible:** orígenes maliciosos. **Rol responsable sugerido:** operaciones; el nombre definitivo requiere aprobación.

Corrección: Restringir orígenes por ambiente. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-09. Compatibilidad MySQL/Postgres/SQLServer no probada

Riesgo: Medio. **Consecuencia posible:** fallos al migrar. **Rol responsable sugerido:** backend/DBA; el nombre definitivo requiere aprobación.

Corrección: Elegir DB oficial y test CI por motor. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

AC-10. Contrato REST sin export OpenAPI versionado

Riesgo: Medio. **Consecuencia posible:** ruptura entre clientes. **Rol responsable sugerido:** integraciones; el nombre definitivo requiere aprobación.

Corrección: publicar snapshot y diff en cada release. **Prevención:** añadir regla de revisión a pipeline, documentar evidencia de la rama/commit y capacitar al equipo involucrado.

Plan de verificación de eficacia: repetir prueba negativa correspondiente, revisar ausencia de regresiones, archivar reportes anonimizados y obtener visto bueno. **Estado:** propuesto/no ejecutado.

8. Procedimiento CAPA y control de calidad

Apertura: registro de no conformidad con descripción factual y evidencia mínima (archivo, ruta, línea y comportamiento). **Causa raíz:** método de cinco porqués o diagrama Ishikawa cuando existan logs y datos; no atribuir causa sin investigación. **Corrección inmediata:** contener riesgo. **Acción correctiva:** eliminar causa confirmada. **Acción preventiva:** identificar defectos similares y bloquear recurrencia (test, checklist, linters, política). **Eficacia:** probar el mismo incidente y flujos adyacentes en versión posterior. **Cierre:** aprobar, documentar y asociar commit.

Indicadores recomendados: tiempo medio hasta detectar/resolver incidentes, tasa de defectos repetidos, cobertura de requisitos críticos, eventos Wompi conciliados, versiones sin regresiones y porcentaje de backups restaurables. Sin mediciones no se proporcionan cifras reales.

Fuentes primarias de implementación

- API: https://github.com/yersonct/SaborExpressBack/tree/main
- Web: https://github.com/yersonct/SaborExpressWeb/tree/main
- Móvil: https://github.com/yersonct/SaborExpressMovil/tree/main
- Referencia de presentación: https://github.com/jsgh1/SRD-v1/tree/dev/docs/docs-SRD

Control documental: documento elaborado a partir del estado observado en octubre de 2026. Antes de entregar, verificar el commit exacto, responsable, revisión del instructor y cualquier cambio posterior del código.

14. Registro de problemas, acciones y responsables por asignar

ID	Hallazgo derivado de inspección	Acción correctiva/preventiva	Evidencia de cierre esperada	Estado
AC-01	README anterior describe Supabase como backend	Actualizar arquitectura a ASP.NET Core 8 + EF	README y manual técnico consistentes	DOCUMENTAL
AC-02	No hay evidencia de pruebas automatizadas en inventario revisado	Crear suite de contrato e integración	CI con reportes verificables	PENDIENTE
AC-03	Webhook accesible anónimamente por diseño	Verificar integridad del evento, referencia y monto	suite Wompi sandbox adversarial	PENDIENTE
AC-04	MigrateAsync ocurre en arranque de API	Separar migración controlada en producción	despliegue y restauración ensayados	PENDIENTE
AC-05	Proveedores DB configurables	Formalizar motor primario y compatibilidad	matriz CRUD/migración por motor	PENDIENTE
AC-06	Distintos clientes consumen misma API	Control de versiones de contratos	pruebas de compatibilidad	PENDIENTE
AC-07	Datos geográficos y de entrega	Evaluar privacidad y retención	política aprobada y prueba acceso	PENDIENTE
AC-08	Documentación anterior contenía archivos vacíos	Conservar expedientes desarrollados y originales	inventario sin vacíos ni bajas no revisadas	DOCUMENTAL

15. Análisis de causa raíz y verificación de eficacia

Toda no conformidad debe registrar fecha, identificador, evidencia y riesgo de continuidad. Usar los cinco porqués o diagrama causal con participantes reales, documentando hechos y no suposiciones. La acción correctiva debe demostrar que la causa fue tratada (por ejemplo, pruebas idempotentes de doble webhook), mientras una acción preventiva verifica que otras rutas del mismo dominio cumplen la regla. Sin test de regresión y aprobación, el caso sigue abierto.

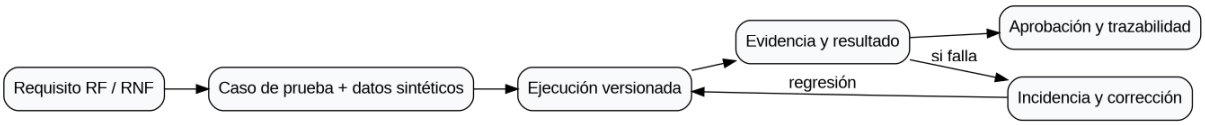


Figura 10. Ciclo de validación recomendado; pruebas no ejecutadas

10_CICLO_QA

Nota. Elaboración para el estudio de caso SaborExpress; las figuras no certifican operaciones desplegadas.